SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I Y. Ramadevi *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

Unauthorized Scope Expansion During a penetration Test

No, I would not exploit the vulnerability without obtaining explict authorization.

Even if the vulnerability is critical, Exploiting a system outside the agreed scope any cause damage, violate privacy, or create legal problems.

1. Ethical principles involved

- Authorization : An ethical hacker must have clear permission before accessing or Exploiting a system
- Defined scope : Testing must be limited to the specified IP addresses, domains, applications and systems.
- Non-maleficence : The tester must avoid causing harm to systems, users, or business operations.
- confidentiality : Sensitive information discovered during testing must be protected.
- Accountability : All testing activities and findings must be documented accurately.
- professional Integrity : An Ethical hacker must follow the agreed rules Even when a vulnerability appears important.

2. Steps I would take

Stop testing the affected System beyond the authorized level.

Record the vulnerability using non-invasive evidence, without accessing sensitive data or disruption services.

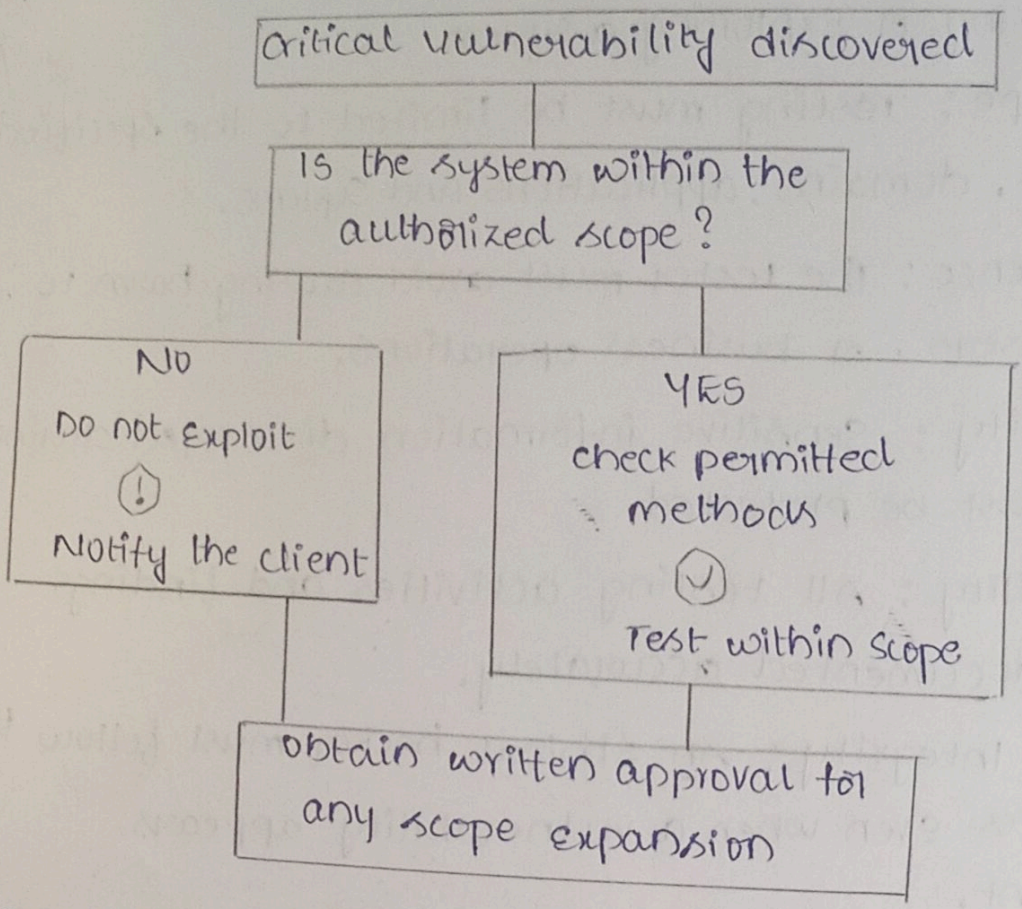
Inform the authorized client contact about the finding and Explain it's potential severity.

Request written authorized to include the system in the testing scope.

continue exploitation only After receiving explicit permissio and agreeing on suitable safeguards.

include the vulnerability, its risk, and the recommended remediation in the final report.

Ethical decision-making



conclusion: Ethical hacking requires permission, clearly defined scope, responsible disclosure, and harm prevention.

A critical vulnerability does not give the tester automatic permission to Exploit an out-of-scope system.

Written authorization protects both the organization and the ethical hacker.

SQL Injection Risk in a production Database containing Real Financial Data.

I would prioritize customer privacy, data security and business continuity. Since the database contains real financial information, I would not perform destructive queries or retrieve unnecessary sensitive records.

I would coordinate with the client and use the safest method to verify the vulnerability.

Steps to proceed safely

- pause Exploitation : Stop before executing queries that could modify, delete, or expose customer information.
- Inform the client : Notify the authorized security contact and explain the potential impact.
- Use a safe testing Environment : prefer a staging environment or an isolated database containg synthetic or anonymized data.
- Use Non-destructive Verification : If explicity authorized, use a controlled input to confirm whether SQL injection exists without extracting real financial records.
- Apply least privileges : Use a dedicated test account with minimal permissions rather than a privileged production database account.
- Monitor database activity : Coordinate with the database administrator and monitor logs, performance, and unusal queries.
- protect evidence : Store only the minimum evidence required, redact sensitive information, and restrict access to the test report.

- Report and recommend fixes: Document the vulnerability and recommend parameterized queries, prepared statements, input validation, and least-privilege database permissions.

Precautions required before the engagement

Obtain written authorization defining the systems and testing methods permitted.

Define the scope, testing window, prohibited actions, and escalation contacts.

Establish rules for handling personal and financial data.

Take verified backups and prepare a recovery procedure.

Use a staging environments and synthetic data wherever possible.

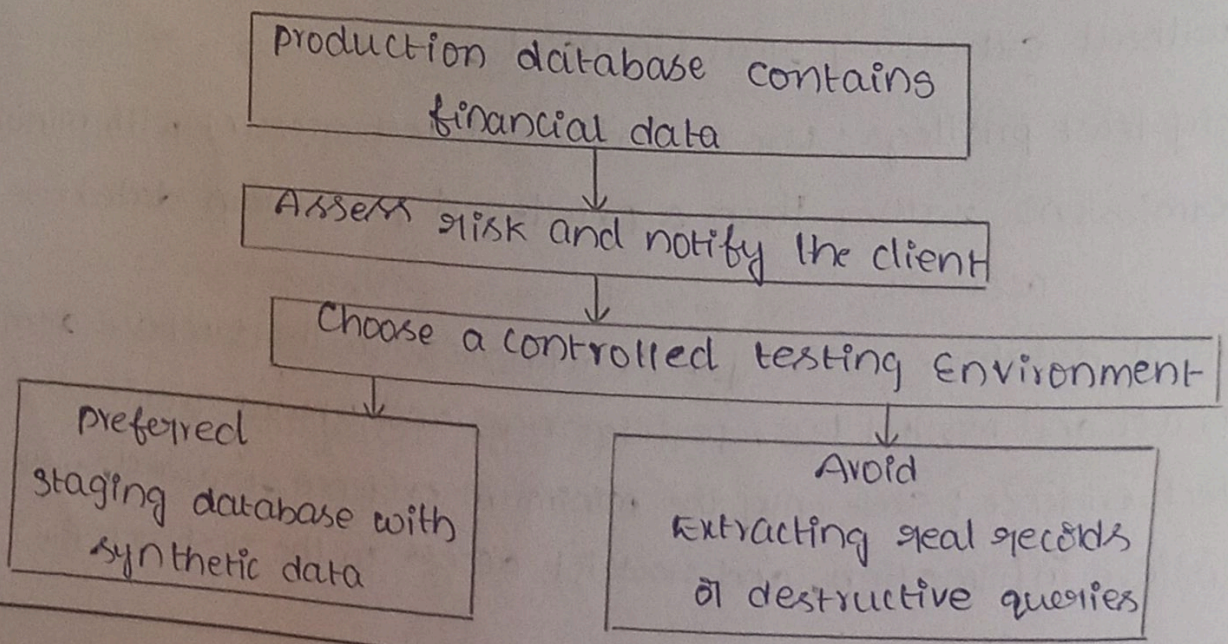
Set monitoring, rate limits, and stop conditions for testing.

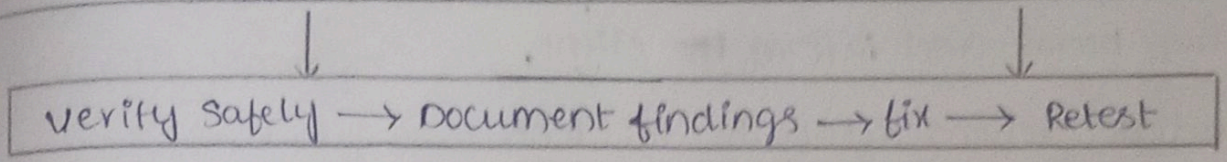
Agree on incident-response procedures if a failure or data exposure occurs.

Define evidence retention, secure storage, and detection requirements.

Confirm applicable legal, regulation, and contact obligations.

Safe SQL Injection Testing





common SQL injection prevention methods

Method	purpose
prepared statements	seperate SQL commands from user input
Input validation	Reject unexpected input
least privilage	Restrict database account permissions
web application firewall(WAF)	Help detect or block suspicious requests
logging and monitoling	identify unusual database activity
Data masking	Reduce exposure of sensitive information
Backups and recovery plans	Support restoration after an incident.

conclusion : the main principle is to prove the vulnerability with the minium possible risk.

Proper authorization, controlled testing, data minimization, backups, and incident-response planning should be established befole testing begins.

protecting real customer data is mole important then demonstra-ting an exploit through unnecessary data exposure.

Q3. Accidental Denial-of-Service During a Black-box pentration Test :

A denial-of-Service occurs when a system becomes unavailable because it resources are overwhelmed or it's services are distrupted.

If my testing causes an outage on a live production server, I must immediately prioritize service restoration, minimize.

further harm, and inform the client.

1. Immediate actions after the incident

- Stop testing immediately : Terminate the activity that caused the outage and avoid sending further requests to the affected server.
- Notify the client : inform the designated contact and incident - response team immediately.
- Assist with recovery : cooperate with authorized system admin -strators to restore the service safely.
- preserve evidence : Maintain relevant timestamps, logs, commands and test records without altering or deleting evidence.
- Identify the cause : Determine which testing activity triggered the failure and document the sequence of events.
- Monitor Recovery : Help verify that the server and it's dependent services are functionaly normal.
- prepare an incident report : Explain the impact, root cause, response actions, and preventive measures.
- Resume only with approval : Continue testing only after the client confirms recovery and approves the revised testing approach.

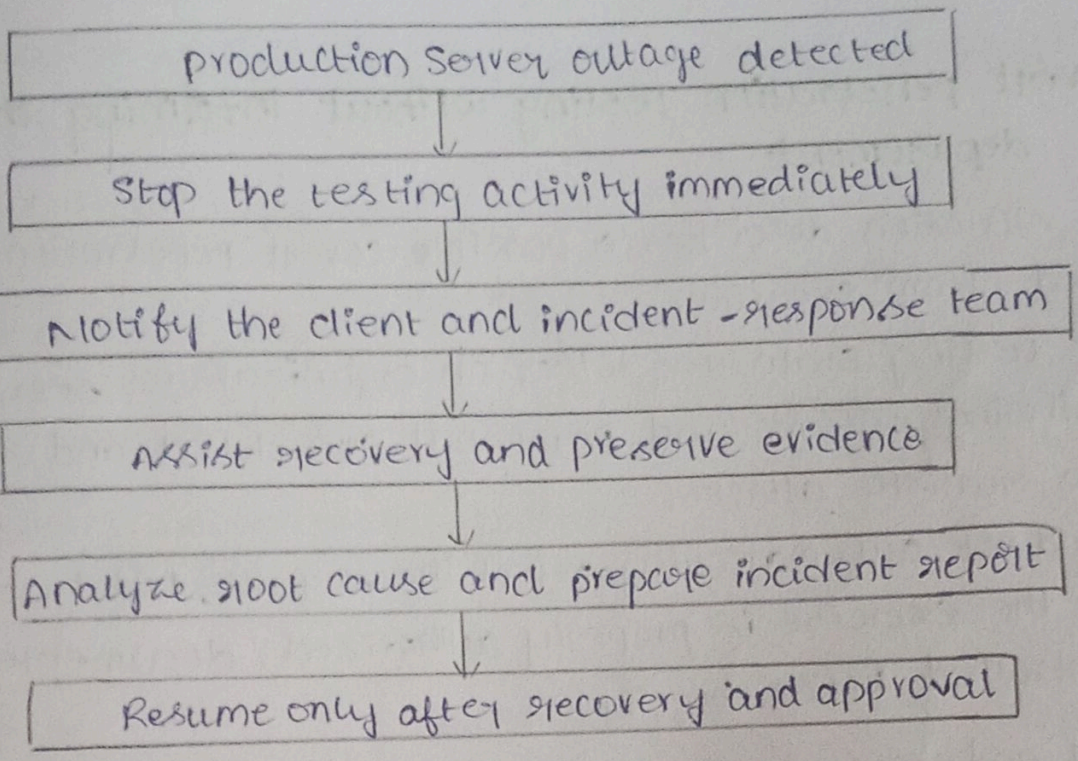
2. preventive measures that should have been taken

Obtain written authorization and clearly define the scope.
Discuss production - system risks before testing begins
Use a staging environment whenever possible.
Avoid uncontrolled traffic generation and aggressive automate scans.
Establish rate limits and conservative testing parameters
schedule testing during an approved maintenance window.
Configure monitoring and alerting to detect service degradation

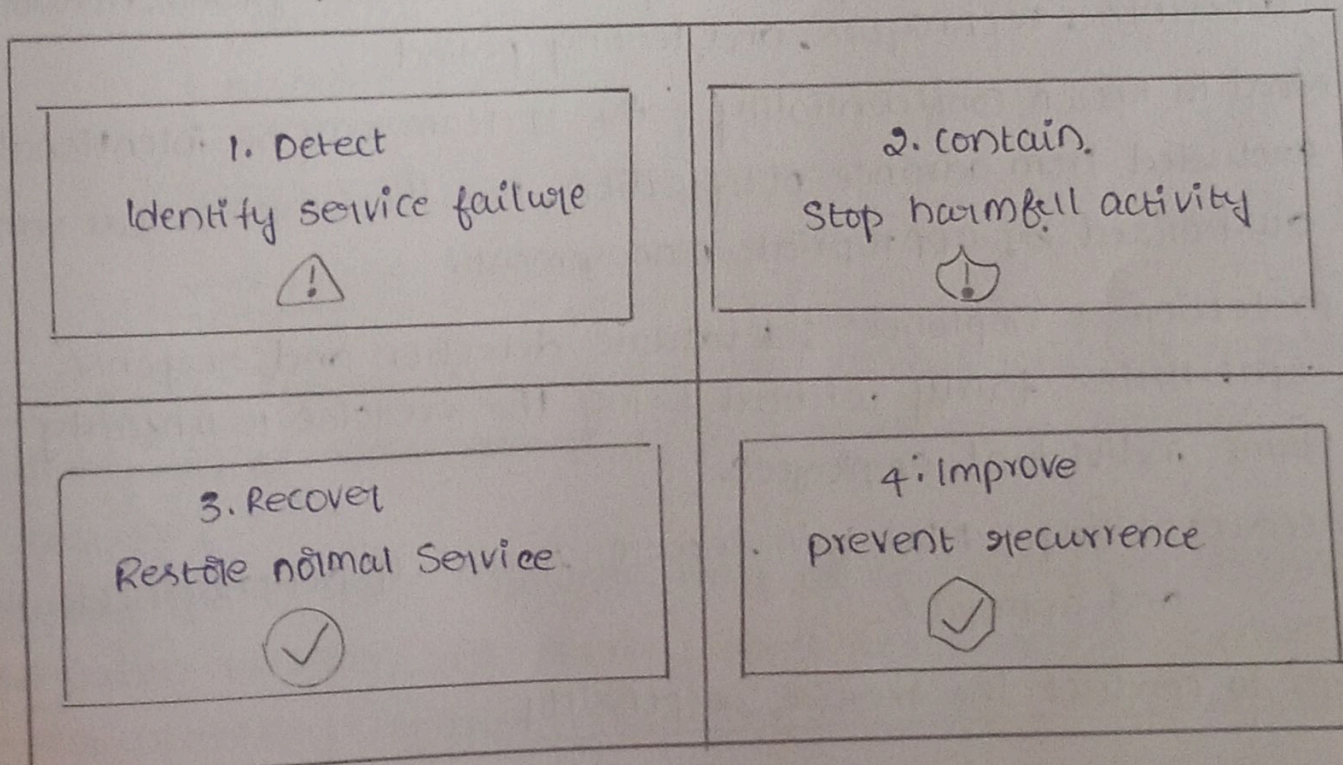
Establish emergency contacts, stop conditions, and a rollback or recovery plan.

Obtain explict approval for denial-of-service testing because it can disrupt availability.

Incident response



Incident management cycle



Conclusion : An Ethical hacker is responsible not only for identifying vulnerabilities but also for minimizing harm and responding transparently when something goes wrong. Immediate cessation, prompt notification, recovery assistance and honest reporting are essential professional responsibilities.

Q4. Covert penetration Testing without Informing the IT department

This situation describes a possible covert penetration test or red-team exercise.

Such testing evaluates wther an organization's security monitoring systems and personnal can detect and respond to realistic attacks.

I would not automatically reject the request, but I would ensure that the exercise is properly authorized, documented and controlled before begninning.

Ethical and legal considerations

- Defined scope : clearly identify the permitted systems, network accounts, techniques, and testing period
- Need to known confidentiality : The IT team may be intentionally excluded from advance notification, but the exercise must remain authorized by appropriate management.
- protection of Employees : Evaluate detection and response capabilities fairly without using the exercise to unfairly blame individual employees.
- Accountability : Maintain secure records of actions, incidents and approvals.

Steps to conduct the exercise responsibly

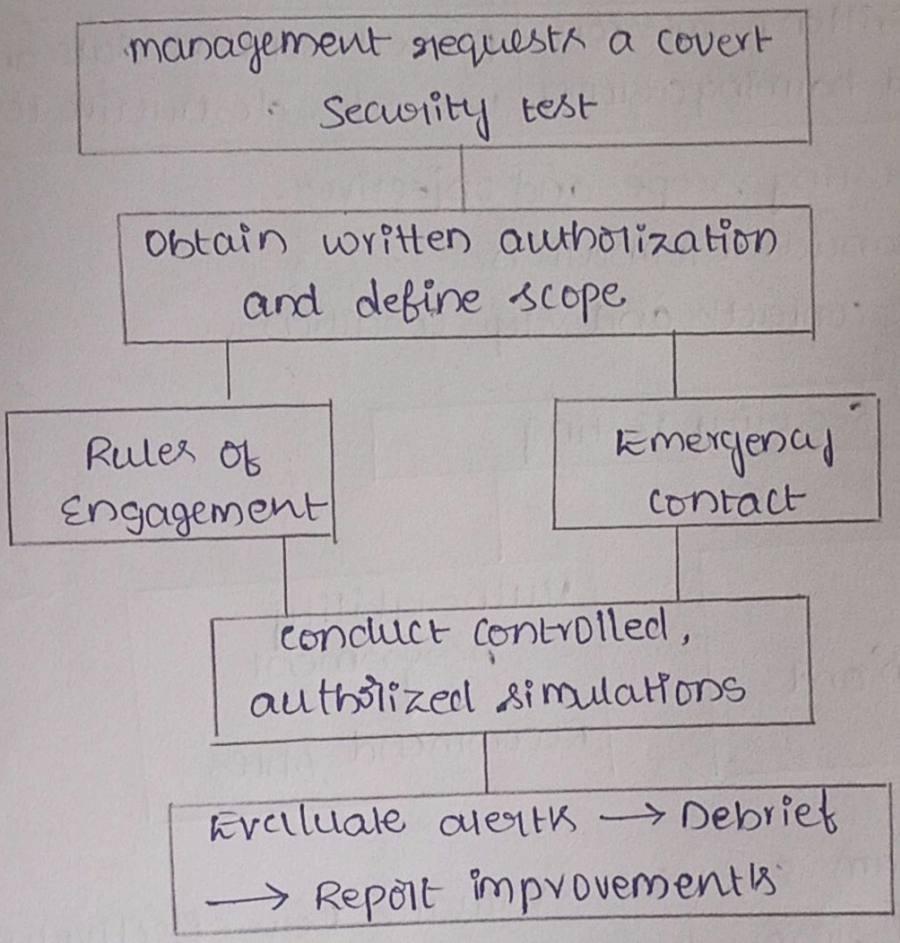
Obtain written approval from authorized management or the designated security authority.

Establish a trusted emergency contact who can authorize the exercise to stop.

Monitor the exercise to ensure it does not exceed the approved scope.

Stop immediately if a critical safety, privacy, or operational risk arises.

Ethical Red-team exercise



conclusion : Covert testing can be ethical when it is properly authorized, scoped, controlled, and designed to improve security.

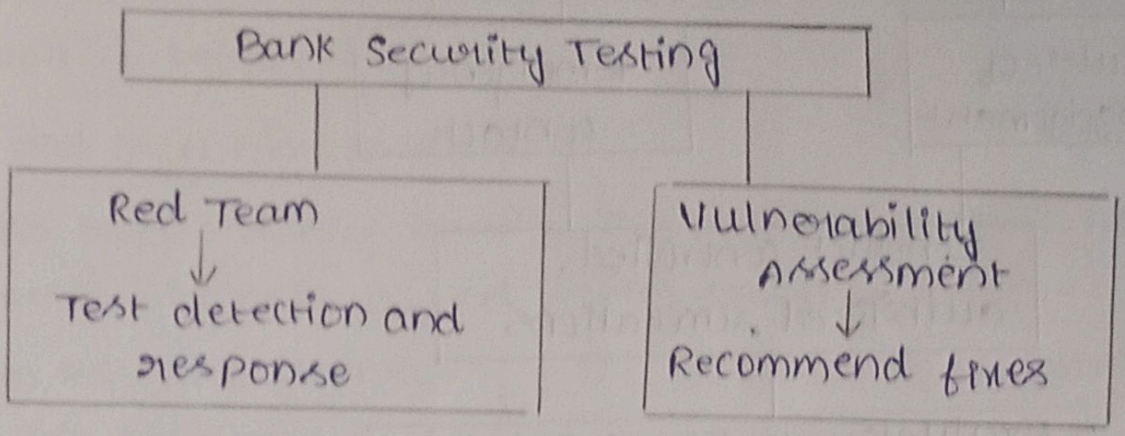
Keeping the IT team unaware may be necessary for realistic detection testing, but secrecy must never replace authorizati accountability, or harm prevention.

Q5. Red Team Exercise Vs Vulnerability Assessment

Scenario : A bank wants to evaluate it's physical and digital security to protect customer data and financial transactions.

Aspect	Red Team Exercise	Vulnerability Assement
objective	Test the bankk ability to detect and realistic attacks.	Identify and report security weaknesses.
Digital security	Simulate controlled attacks on banking applications.	Identify outdated software, weak passwords.
Ethics	obtain written permission and avoid harming customer.	Protect senitive data and use safe, destructive test.

clearly define the testing scope and objectives.
protect customer financial information
Establish emergency contacts and stop conditions.



Conclusion : A red team exercise evaluates how effectively the bank detects and responds to simulated attacks, where as a vulnerability assessment identifies security weaknesses without attempting a full attack.
Both requires written authorization, defined scope, confiden-tiality, and responsible reporting.